BUSINESS REQUIREMENTS DOCUMENT (BRD)
& BUSINESS USE CASE SPECIFICATION

Project: Explainable AI-Based Insider Threat Detection via Network Behavior Analysis in Software-Defined Networking (SDN) Environments Using SHAP/LIME

Author / Lead Security Architect: Yashwanth Pathiwada

Target Environment: Enterprise SDN Infrastructure (OpenFlow 1.3 / Open vSwitch / Ryu)

Document Version: 1.0 (Production Release)

Classification: Confidential / Academic Final Year Project Submission

Date of Publication: October 2026

1. Document Control & Approvals

This document serves as the definitive Business Requirements Document (BRD) and Use Case Specification for the Explainable AI (XAI) Insider Threat Detection platform in Software-Defined Networks. It establishes the functional, architectural, regulatory, and business requirements necessary to detect, explain, and mitigate insider cyber threats.

Role	Name / Designee	Title	Approval Status
Lead Security Architect	Yashwanth Pathiwada	Final Year Project Lead	APPROVED
Academic Project Examiner	Faculty Review Board	Dept. of Computer Science & Cybersecurity	REVIEWED
Enterprise SOC Advisor	Cybersecurity Practice	Security Operations Advisory	ACCEPTED

2. Executive Summary & Strategic Business Context

In modern digital enterprise infrastructures, malicious or compromised insiders represent one of the highest-impact cybersecurity threats. Insiders already hold authorized credentials, possess physical or VPN network connectivity, and understand organizational workflows. Consequently, conventional perimeter defenses—including Next-Generation Firewalls (NGFW) and signature-based Network Intrusion Detection Systems (NIDS)—are fundamentally inadequate to detect authorized users abusing their legitimate access.

This platform bridges this critical vulnerability by combining the programmable traffic orchestration of Software-Defined Networking (OpenFlow 1.3) with Explainable Artificial Intelligence (XAI). By continuously extracting behavioral features across 10-second sliding windows, fusing supervised and unsupervised machine learning models, and decomposing decisions via game-theoretic SHAP attributions, the system empowers Security Operations Center (SOC) analysts to detect, understand, and surgically mitigate insider threats in real time without causing algorithmic denial-of-service.

3. Business Problem Statement & Market Opportunity

Enterprise cybersecurity executives face three compounding operational challenges that this project resolves:

1. Lateral Visibility Blackout: Internal east-west traffic between workstations and internal database servers often bypasses perimeter inspection devices entirely.

2. The Black-Box AI Trust Barrier: SOC analysts routinely distrust or ignore complex Machine Learning anomaly alerts because standard deep models provide zero causal justification.

3. False-Positive Induced Denial of Service: Automated intrusion prevention systems that unilaterally isolate high-volume workstations risk shutting down mission-critical executive or payroll operations during legitimate end-of-quarter workloads.

> **BUSINESS VALUE PROPOSITION:** *According to the 2025 Cost of Insider Threats Global Report by the Ponemon Institute, the average annualized cost of an insider incident exceeds $16.2 million, with an average containment time of 86 days. Real-time SDN telemetry and transparent XAI reduce containment time from months to under 15 seconds.*

4. Stakeholder Profiles & RACI Matrix

Project Capability / Lifecycle Stage	CISO	Tier-2 SOC Analyst	SDN NetOps Engineer	Compliance Auditor
OpenFlow Telemetry & Switch Deployment	I	I	R / A	I
Feature Extraction & Risk Threshold Tuning	C	R	C	I
Elevated Threat Alert Review & Playbook Approval	I	R / A	C	I
OpenFlow Isolation & Rollback Enforcement	I	R	A	I
Forensic Investigation Dossier & Audit Review	A	C	I	R

Legend: R = Responsible for execution | A = Accountable for outcome | C = Consulted for expertise | I = Informed of status.

5. In-Depth Business Use Cases (Enterprise Scenarios)

5.1 Primary Business Use Case: Confidential Financial Intellectual Property Exfiltration

• Organization Profile: Multinational Investment Bank managing proprietary algorithmic trading models, high-frequency execution strategies, and customer portfolio repositories.

• Threat Actor: Disgruntled Senior Financial Quant (Host IP: 10.0.1.11, Role: Finance Workstation) who has tendered his resignation to join a rival hedge fund.

• Threat Narrative: At 02:30 AM on a Saturday, the employee initiates an unauthorized bulk transfer of 2.5 GB of financial model databases and client lists to an external cloud server (10.0.3.100) over encrypted port 443.

• Legacy Security Failure: The employee's valid domain credentials and VPN connection permitted access. Perimeter firewalls allowed outbound HTTPS, and payload encryption prevented Deep Packet Inspection (DPI).

• System Detection & Mitigation Workflow:

1. OpenFlow Telemetry Capture: Ryu controller's 1-second statistics poller captured an explosive transmission rate spike (850 KB/s) from 10.0.1.11.

2. Behavioral Feature Pipeline: Computed 10-second sliding-window features: bytes_per_sec = 850,000, off_hours_ratio = 1.0 (weekend), external_traffic_ratio = 1.0, and baseline Z-score = +5.8.

3. Multi-Model Risk Fusion: Cost-sensitive Random Forest predicted P_sup = 0.993; Isolation Forest scored S_unsup = 0.941; Context Risk Flag fired at 0.90. Fused Risk Score: s_fused = 0.958 (CRITICAL SEVERITY).

4. Transparent XAI Explanation: SHAP TreeExplainer decomposed the exact push factors (+0.0747 total_bytes, +0.0661 bytes_per_sec, +0.0546 off-hours ratio). Additivity fidelity confirmed at 0.000000 error within 1.95 ms.

5. MITRE ATT&CK Mapping: Correlated to Technique T1048.003 (Exfiltration Over Web Service) and NIST SP 800-53 Control SC-7.

6. Policy-Gated Response: SOC Analyst approved a 120-second Surgical Playbook on the dashboard. Controller immediately pushed a priority 65000 OpenFlow DROP rule to Switch s1, halting the transfer in under 15 seconds.

• Financial & Business Impact: Prevented an estimated $14.2M regulatory non-compliance penalty (under GDPR/GLBA), preserved proprietary algorithmic trading IP, and prevented competitive client asset drainage.

5.2 Secondary Business Use Case: Internal Lateral Reconnaissance & Port Scanning

• Organization Profile: Large Hospital Network operating electronic health records (EHR) and connected biomedical systems.

• Threat Actor: Compromised HR workstation (Host IP: 10.0.1.10) running an automated stealth port scan across the subnet to locate listening database ports (5432, 1433, 3306).

• Detection & Containment: Feature extractor identified anomalous destination port Shannon entropy ($H > 2.5$) with low packet counts per flow (SYN-only probes). LIME rules confirmed

'dst_port_entropy > 2.0'. Analyst authorized a Rate-Limiting quarantine rule, preserving emergency medical communications while blocking reconnaissance probes.

5.3 Tertiary Business Use Case: Unauthorized Database Privilege Abuse

• Threat Scenario: Standard employee workstation attempting direct PostgreSQL queries against internal server 10.0.2.10:5432.

• Containment: Policy engine enforced Surgical Micro-Segmentation—blocking strictly port 5432 traffic from that workstation via OpenFlow match without disconnecting the user's corporate email or intranet.

6. Detailed Functional Requirements (FR)

Req ID	Module	Functional Requirement Description	Priority
FR-01	Module 1	System shall establish OpenFlow 1.3 connectivity with Mininet Open vSwitch instances.	Mandatory
FR-02	Module 1	Ryu controller shall poll flow statistics (OFPFlowStatsRequest) every 1.0 second.	Mandatory
FR-03	Module 1	System shall expose a REST API (Port 8080) for policy mitigation and status querying.	Mandatory
FR-04	Module 2	System shall aggregate flow records into 10-second host sliding windows with 5-second steps.	Mandatory
FR-05	Module 2	Pipeline shall compute 25 behavioral features across Volume, Rate, Temporal, Behavioral, and Context groups.	Mandatory
FR-06	Module 2	System shall compute Shannon entropy for destination IPs and destination ports.	Mandatory
FR-07	Module 3	System shall train a Cost-Sensitive Random Forest classifier with balanced	Mandatory

		class weights.	
FR-08	Module 3	System shall train an Isolation Forest detector strictly on benign baseline traffic.	Mandatory
FR-09	Module 3	System shall fuse supervised probability, unsupervised score, and context flags into s_fused.	Mandatory
FR-10	Module 4	System shall generate exact SHAP TreeExplainer attributions and verify mathematical additivity.	Mandatory

7. Non-Functional Requirements (NFR)

• NFR-01 (Explainability Latency): SHAP TreeExplainer computation overhead must execute in less than 50 milliseconds per 10-second window (empirical benchmark: 1.95 ms).

• NFR-02 (Telemetry Processing Overhead): OpenFlow 1.0-second statistics poller must consume less than 3% CPU utilization on standard 4-core server.

• NFR-03 (Additivity Fidelity Margin): Mathematical discrepancy between the sum of Shapley values plus base expected value and the model output must be less than 0.05 ($|\text{sum}(\text{phi}) + \text{phi}_0 - f(x)| < 0.05$).

• NFR-04 (Zero Data Leakage): Preprocessing scalers (RobustScaler) must be fitted strictly on benign training data splits to ensure no test or anomaly leakage occurs.

• NFR-05 (Availability & Fault Tolerance): If the Ryu controller REST API is temporarily unreachable, the Streamlit dashboard must seamlessly degrade to local SQLite policy mitigation buffering.

8. Regulatory & Compliance Alignment

Regulatory Standard	Mapped Control ID	System Implementation Mechanism
NIST SP 800-53 Rev. 5	SC-7 Boundary Protection & AC-4 Flow Enforcement	OpenFlow 1.3 switch isolation flow rules and surgical port blocking.
NIST SP 800-53 Rev. 5	AU-6 Audit Record Review, Analysis & Reporting	Immutable SQLite audit log and 1-click formal forensic HTML/PDF dossier.
GDPR (Article 32 & 33)	Security of Processing & Breach Notification	Immediate detection of bulk personal data exfiltration with automated containment.

ISO/IEC 27001:2022	Control A.8.16 Monitoring Activities	Real-time sliding-window behavioral analysis and digital twin network visualization.

9. Acceptance Criteria & Quality Test Matrix

All functional and performance criteria have been validated under automated test suites:

1. Precision & Recall: Must achieve greater than 95% on test split (Achieved: Precision 1.000, Recall 1.000, ROC-AUC 1.000).

2. Time-To-Live Rollback: Flow rules must automatically expire after TTL duration (Verified: 60s rule auto-reverted without switch reboot).

3. XAI Additivity: SHAP fidelity error must pass additivity test (Verified: 0.000000 error).

10. Conclusion & Strategic Roadmap Link

The Explainable AI-Based Insider Threat Detection in SDN platform establishes a novel, production-validated paradigm for enterprise network security. By providing transparent, mathematically validated justifications alongside human-in-the-loop OpenFlow mitigation, it eliminates analyst fatigue and prevents costly operational disruptions.

For the complete multi-phase engineering evolution (including P4 programmable data planes, Temporal Graph Neural Networks, and Autonomous LLM Agents), refer to the official repository roadmap at: https://github.com/yashwanthPathiwada/explainable-sdn-insider-threat/blob/main/ROADMAP.md